INFORME DE SEGURIDAD WEB

www.ejemplo.com

Cliente: Tienda Ejemplo SpA **Sitio:** https://www.ejemplo.com/ **Fecha:** 9 de noviembre de 2026

Preparado por: Tu Nombre o Empresa



Riesgoso

Puntaje de seguridad, de 0 a 100. Es orientativo y sirve para priorizar.

Resumen para la gerencia

Realizamos un análisis pasivo: observamos cómo responde el sitio, sin intentar vulnerarlo sobre **www.ejemplo.com**. El resultado general es **riesgoso** (40/100). Hay problemas que un atacante podría aprovechar.

Detectamos **13 puntos** a revisar, de los cuales **1** es urgente. Buena noticia: **10** se pueden resolver en pocos minutos.

Lo primero que hay que atender:

- Certificado TLS vencido

13
Puntos a revisar
en total, de todas las severidades

1
Urgentes
severidad crítica o alta

10
Arreglos rápidos
se resuelven en minutos

8
Controles ejecutados
áreas de seguridad revisadas

Por severidad

Cuántos puntos hay según qué tan grave es cada uno.

Crítica	0
Alta	1
Media	5
Baja	5
Informativo	2

Por área

Estado de cada área de seguridad revisada.

Conexión segura (HTTPS)

Que lo que viaja entre tus visitantes y el sitio vaya cifrado, y que el sitio sea auténtico.

2 puntos a revisar

Escudos del navegador

Instrucciones que el sitio le da al navegador para defenderse de ataques comunes.

7 puntos a revisar

Sesiones y cookies

Cómo se protegen los datos que recuerdan quién es cada visitante.

2 puntos a revisar

Acceso desde otros sitios

Qué otras páginas web pueden pedirle datos a tu sitio.

Sin problemas

Contenido y formularios

Cómo está construida la página: formularios, scripts externos y datos visibles en el código.

Sin problemas

Correo y dominio

Que nadie pueda enviar correos falsos haciéndose pasar por tu empresa.

1 punto a revisar

Archivos expuestos

Archivos internos que no deberían poder verse desde internet.

1 punto a revisar

Lo que está bien

Áreas revisadas donde no encontramos problemas.

Acceso desde otros sitios

Contenido y formularios

Plan de acción

Qué corregir y en qué orden. Dentro de cada grupo, lo más rápido de resolver va primero. Haz clic en un punto para ver su explicación.

Urgente
esta semana

Certificado TLS vencido

Rápido · minutos

Quien administra el hosting o servidor

Importante
durante este mes

Sin registro DMARC

Rápido · minutos

Quien administra el dominio y el correo

Sin protección contra clickjacking

Rápido · minutos

Quien administra el hosting o servidor

Falta Strict-Transport-Security (HSTS)

Rápido · minutos

Quien administra el hosting o servidor

HTTP no redirige a HTTPS

Rápido · minutos

Quien administra el hosting o servidor

Falta Content-Security-Policy (CSP)

Mayor · días

Quien desarrolla o mantiene el sitio web

Mejora continua
cuando haya oportunidad

Cookie sin atributo HttpOnly

Rápido · minutos

Quien desarrolla o mantiene el sitio web

Cookie sin atributo SameSite

Rápido · minutos

Quien desarrolla o mantiene el sitio web

Divulgación de tecnología en Server

Rápido · minutos

Quien administra el hosting o servidor

Falta X-Content-Type-Options: nosniff

Rápido · minutos

Quien administra el hosting o servidor

Falta Referrer-Policy

Rápido · minutos

Quien administra el hosting o servidor

Sin security.txt

Rápido · minutos

Quien desarrolla o mantiene el sitio web

Falta Permissions-Policy

Rápido · minutos

Quien administra el hosting o servidor

Detalle de hallazgos

Cada punto explica qué significa, por qué importa y cómo se corrige, sin tecnicismos.
El detalle técnico está al final de cada uno, para quien lo implemente.

Alta **Certificado TLS vencido** · Conexión segura (HTTPS)

¿QUÉ SIGNIFICA?
El certificado de seguridad del sitio ya venció, como un documento de identidad caducado.

¿POR QUÉ IMPORTA?
Los navegadores bloquean o advierten al visitante al entrar, se pierde confianza y ventas, y el sitio puede dejar de funcionar para integraciones.

¿CÓMO SE ARREGLA?
Renovar el certificado hoy mismo y activar la renovación automática para que no vuelva a ocurrir.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
Venció el 2026-11-01.

Recomendación técnica
Renueva el certificado.

Más información
https://developer.mozilla.org/es/docs/Web/Security/Transport_Layer_Security

Identificador
`tls.expired`

Media **Sin registro DMARC** · Correo y dominio

¿QUÉ SIGNIFICA?
El dominio no indica qué hacer con correos que dicen ser tuyos pero no lo son.

¿POR QUÉ IMPORTA?
Los estafadores pueden enviar correos falsos con tu nombre a tus clientes sin que los servidores los frenen.

¿CÓMO SE ARREGLA?
Publicar un registro DMARC; empezar en modo monitoreo y subir gradualmente la exigencia.

Rápido · minutos

Quien administra el dominio y el correo

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No se encontró un registro TXT en _dmarc.ejemplo.com.

Recomendación técnica
Publica un registro DMARC, comenzando con p=none y subiendo gradualmente.

Identificador
`dns.dmarc_missing`

Media **Sin protección contra clickjacking** · Escudos del navegador

¿QUÉ SIGNIFICA?
Otra página podría mostrar tu sitio escondido dentro de la suya para engañar a los usuarios y hacerles hacer clic donde no quieren (clickjacking).

¿POR QUÉ IMPORTA?
Un visitante podría, sin saberlo, aprobar una compra, un cambio de datos o un permiso.

¿CÓMO SE ARREGLA?
Agregar la cabecera X-Frame-Options o la directiva frame-ancestors en la política CSP.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No hay X-Frame-Options ni frame-ancestors en la CSP.

Recomendación técnica
Agrega X-Frame-Options: DENY o la directiva frame-ancestors 'none'.

Identificador
`headers.clickjacking`

Media **Falta Content-Security-Policy (CSP)** · Escudos del navegador

¿QUÉ SIGNIFICA?
El sitio no define una 'lista de invitados' de qué scripts y recursos puede cargar.

¿POR QUÉ IMPORTA?
Si un atacante lograra insertar código malicioso en la página, el navegador lo ejecutaría sin cuestionarlo (robo de datos, formularios falsos).

¿CÓMO SE ARREGLA?
Definir una política Content-Security-Policy que permita solo los orígenes que el sitio realmente usa.

Mayor · días

Quien desarrolla o mantiene el sitio web

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No se envía Content-Security-Policy.

Recomendación técnica
Define una CSP restrictiva que limite los orígenes de scripts y recursos.

Más información
https://developer.mozilla.org/es/docs/Web/HTTP/CSP

Identificador
`headers.csp`

Media **Falta Strict-Transport-Security (HSTS)** · Escudos del navegador

¿QUÉ SIGNIFICA?
El sitio no le indica al navegador que debe usar SIEMPRE la conexión segura.

¿POR QUÉ IMPORTA?
Un atacante en la misma red WiFi podría forzar una conexión sin cifrar la primera vez que alguien visita.

¿CÓMO SE ARREGLA?
Agregar la cabecera Strict-Transport-Security con una duración larga (por ejemplo, un año).

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
La respuesta no incluye la cabecera Strict-Transport-Security.

Recomendación técnica
Agrega 'Strict-Transport-Security: max-age=31536000; includeSubDomains'.

Más información
https://developer.mozilla.org/es/docs/Web/HTTP/Headers/Strict-Transport-Security

Identificador
`headers.hsts`

Media **HTTP no redirige a HTTPS** · Conexión segura (HTTPS)

¿QUÉ SIGNIFICA?
Quien escribe la dirección sin 'https' entra a una versión sin cifrar del sitio.

¿POR QUÉ IMPORTA?
Esas visitas viajan sin protección: en una red WiFi pública alguien podría ver o alterar lo que hacen.

¿CÓMO SE ARREGLA?
Configurar una redirección automática de http:// a https:// en todo el sitio.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
http://www.ejemplo.com/ responde 200 sin redirigir a HTTPS.

Evidencia

```
GET http://www.ejemplo.com/ -> 200
```

Recomendación técnica
Configura una redirección 301 de HTTP a HTTPS.

Identificador
`transport.no_redirect`

Baja **Cookie sin atributo HttpOnly** · Sesiones y cookies

¿QUÉ SIGNIFICA?
Los scripts de la página pueden leer las cookies de sesión.

¿POR QUÉ IMPORTA?
Si algún script malicioso se colara, podría robar la sesión del usuario.

¿CÓMO SE ARREGLA?
Marcar las cookies de sesión con el atributo HttpOnly.

Rápido · minutos

Quien desarrolla o mantiene el sitio web

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
La cookie 'sessionid' no tiene HttpOnly.

Evidencia

```
Set-Cookie: sessionid=...; Path=/
```

Recomendación técnica
Agrega el atributo HttpOnly a las cookies de sesión.

Identificador
`cookies.httponly`

Baja **Cookie sin atributo SameSite** · Sesiones y cookies

¿QUÉ SIGNIFICA?
Las cookies no indican si pueden enviarse cuando la petición viene desde otro sitio.

¿POR QUÉ IMPORTA?
Facilita ataques en los que otra web hace acciones en nombre del usuario (CSRF).

¿CÓMO SE ARREGLA?
Definir el atributo SameSite (Lax o Strict) en las cookies.

Rápido · minutos

Quien desarrolla o mantiene el sitio web

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
La cookie 'sessionid' no define SameSite.

Evidencia

```
Set-Cookie: sessionid=...; Path=/
```

Recomendación técnica
Define SameSite=Lax o Strict.

Identificador
`cookies.samesite`

Baja **Divulgación de tecnología en Server** · Escudos del navegador

¿QUÉ SIGNIFICA?
El servidor anuncia con qué tecnología y versión está hecho, como dejar un letrero con el modelo de tu cerradura.

¿POR QUÉ IMPORTA?
Facilita a un atacante buscar fallas conocidas de esa versión exacta.

¿CÓMO SE ARREGLA?
Ocultar o simplificar esa cabecera en la configuración del servidor.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis

La cabecera Server revela la tecnología y versión.

Evidencia

```
Server: Apache/2.4.41 (Ubuntu)
```

Recomendación técnica

Oculta o genericiza la cabecera.

Identificador

`headers.disclosure.server`

Baja **Falta X-Content-Type-Options: nosniff** · Escudos del navegador

¿QUÉ SIGNIFICA?
El navegador puede 'adivinar' el tipo de un archivo en lugar de confiar en lo que dice el servidor.

¿POR QUÉ IMPORTA?
Un archivo subido como imagen podría llegar a ejecutarse como script.

¿CÓMO SE ARREGLA?
Agregar la cabecera X-Content-Type-Options con el valor nosniff.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis

No se envía X-Content-Type-Options.

Recomendación técnica

Agrega 'X-Content-Type-Options: nosniff'.

Identificador

`headers.nosniff`

Baja **Falta Referrer-Policy** · Escudos del navegador

¿QUÉ SIGNIFICA?
Al hacer clic en un enlace externo, el sitio le cuenta al destino exactamente de qué página venía.

¿POR QUÉ IMPORTA?
Pueden filtrarse direcciones internas o datos incluidos en la URL.

¿CÓMO SE ARREGLA?
Agregar la cabecera Referrer-Policy (por ejemplo, strict-origin-when-cross-origin).

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No se envía Referrer-Policy.

Recomendación técnica
Agrega 'Referrer-Policy: strict-origin-when-cross-origin'.

Identificador
`headers.referrer`

Informativo **Sin security.txt** · Archivos expuestos

¿QUÉ SIGNIFICA?
El sitio no publica un contacto para que investigadores reporten fallas de seguridad.

¿POR QUÉ IMPORTA?
Si alguien encuentra un problema, no sabrá a quién avisar de forma responsable.

¿CÓMO SE ARREGLA?
Publicar un archivo security.txt con un correo de contacto.

Rápido · minutos

Quien desarrolla o mantiene el sitio web

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No se encontró /.well-known/security.txt con un contacto.

Recomendación técnica
Publica un security.txt con un correo de contacto.

Identificador
`exposure.security_txt`

Informativo **Falta Permissions-Policy** · Escudos del navegador

¿QUÉ SIGNIFICA?
El sitio no restringe qué funciones del dispositivo (cámara, micrófono, ubicación) puede usar la página.

¿POR QUÉ IMPORTA?
Es una medida de orden: reduce el daño si algún script externo fuese comprometido.

¿CÓMO SE ARREGLA?
Agregar la cabecera Permissions-Policy desactivando lo que el sitio no necesita.

Rápido · minutos

Quien administra el hosting o servidor

▼ Detalle técnico (para quien implementa)

Lo que detectó el análisis
No se envía Permissions-Policy.

Recomendación técnica
Agrega Permissions-Policy desactivando las funciones que no uses.

Identificador
`headers.permissions`

Alcance de este informe

Qué se revisó

- **headers**: Cabeceras de seguridad que protegen al visitante en el navegador.
- **transport**: Que el sitio obligue a usar la versión segura (HTTPS).
- **cookies**: Configuración de seguridad de las cookies de sesión.
- **cors**: Qué sitios externos pueden leer información de tu sitio.
- **content**: Formularios, scripts externos y datos sensibles en el código de la página.
- **tls**: Certificado digital y versión del cifrado del sitio.
- **dns**: Registros de correo (SPF, DMARC) y de certificados (CAA) del dominio.
- **exposure**: Archivos de configuración, respaldos o carpetas visibles por error.

Qué debes tener en cuenta

- Fue un análisis pasivo: no se intentó vulnerar el sitio ni se enviaron ataques de prueba.
- Es una fotografía del momento: el estado puede cambiar con cada actualización del sitio.
- Un puntaje alto no garantiza que no existan vulnerabilidades; solo indica que lo revisado está bien.
- No se revisó el código interno, la base de datos ni los sistemas de la empresa fuera del sitio.
- El puntaje es una guía orientativa para priorizar, no una certificación.

Glosario

Términos técnicos que aparecen en este informe, explicados en simple.

Certificado TLS
El 'carnet de identidad' digital del sitio. Lo emite una entidad confiable y tiene fecha de vencimiento.

DMARC
Registro que indica qué hacer con los correos que no pasan las verificaciones de SPF/DKIM.

SPF
Registro del dominio que lista qué servidores pueden enviar correo con tu nombre.

Clickjacking
Engaño en el que el sitio se muestra invisible bajo otra página para que el usuario haga clic sin saberlo.

Cabecera
Mensajes que el servidor envía junto con la página para dar instrucciones al navegador.

CSP
Content-Security-Policy: lista de los orígenes desde los que el sitio permite cargar scripts y recursos.

XSS
Cross-Site Scripting: un atacante logra que la página ejecute código malicioso en el navegador de otras personas.

HSTS
Una orden al navegador: 'con este sitio habla siempre por HTTPS'.

HTTPS
La versión segura de la web: cifra lo que viaja entre el visitante y el sitio (el candado del navegador).

Cookie
Pequeño dato que el sitio guarda en el navegador para recordar al visitante (por ejemplo, su sesión).

CSRF
Ataque que aprovecha que el usuario ya inició sesión para hacer acciones sin su consentimiento.

security.txt
Archivo público con el contacto para reportar fallas de seguridad.

Informe generado por Tu Nombre o Empresa el 9 de noviembre de 2026. Creado con report-generator v1.0.0. Este documento es confidencial y está dirigido a Tienda Ejemplo SpA.